PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Prévention et gestion des fuites de données

03-250 ANSSI - Se protéger des fuites de données — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La direction et les salariés doivent être sensibilisés à leur rôle et aux impacts d'une compromission.
2. La protection des données dès la conception et par défaut impose d'intégrer la protection des données personnelles à toutes les étapes de conception d'une application.
3. La minimisation des accès peut s'effectuer par rôle, par zone du système d'information ou par créneaux horaires.

Sensibilisation et évaluation des risques

Notion	À retenir
Sensibilisation	**Direction et salariés** : doivent être sensibilisés au **rôle** dans la protection des données et aux **impacts** d'une compromission.
Risques tiers	**Sous-traitants et fournisseurs** : évaluer les risques de **partage de données** et assurer la **contractualisation** de la sécurisation.

Conception et gestion des données

Notion	À retenir
Protection dès la conception	Appliquer le principe du **RGPD** (protection dès la conception et par défaut) via des **règles restrictives** sur l'**export massif** de données.
Gestion liée aux métiers	Identifier les données **sensibles**, **personnelles**, **régulées**, **propriété intellectuelle** ou **révocables** (**mots de passe**, **tokens**) ; ne stocker que le **nécessaire**.

Préparation à la crise

Notion	À retenir
Procédures et contacts	Procédures de **gestion de crise** à jour ; contacts : **CNIL**, **ANSSI**, gendarmerie, **cybermalveillance.gouv.fr**, prestataires, clients, **DPO**.
Communication de crise	Établie **en amont** (guide « Anticiper et gérer sa communication de crise cyber »).

Sécurité des données et des traitements

Notion	À retenir
Mesures physiques et informatiques	Assurer la **confidentialité** via la **sécurité des accès aux locaux** (physique) et la **défense en profondeur**, le **chiffrement** (stockées/transit), l'**antivirus** ou l'**EDR** (informatique).
Accès d'administration et maintien	Mettre en place des **accès d'administration sécurisés et dédiés** pour les **sous-traitants**, ainsi que le **maintien en condition opérationnelle** et le **maintien en condition de sécurité** du SI.

Gestion des accès et des privilèges

Notion	À retenir
Authentification et rôles	Appliquer l'**authentification multifacteur** et les **mots de passe**, en évitant le **cumul des rôles**.
Minimisation et supervision	Minimiser les accès par **rôle**, **zone** (développement, production, préproduction) et **créneaux horaires**. Mettre en œuvre la **supervision** et la **journalisation** protégée.

Outils et veille

Notion	À retenir
Nomadisme numérique	Adopter **filtres écran de confidentialité** et **verrouillage automatique des sessions**. Déployer/superviser **logiciels DLP** ou **coffre-fort numérique**.
Veille	Réaction : via `haveibeenpwned.com`. Anticipation : **veille sectorielle** ou **CTI** (renseignement sur la menace cyber), en interne ou via prestataire.

Objectif de la compréhension de la source

> En cas de **fuite de données avérée**, comprendre sa source permet d'adopter une **remédiation adéquate** et d'éviter une **nouvelle compromission** par le même vecteur (exemple : un **infostealer**).

Pièges et confusions

- ⚠ Confondre la compréhension de la source d'une fuite avec l'étape de remédiation elle-même.
- ⚠ Oublier que la minimisation des accès peut se faire par créneaux horaires en plus des rôles et des zones.
- ⚠ Oublier de préparer en amont la liste des contacts de crise (CNIL, ANSSI, DPO…) et la communication.

Sigles et définitions

Fuite de données	Compromission, volontaire ou non, de données conduisant à leur divulgation à des tiers non autorisés.
Protection des données dès la conception et par défaut	Principe issu du RGPD imposant d'intégrer la protection des données personnelles à toutes les étapes de conception d'une application.
DLP	Logiciel permettant de détecter et de prévenir la fuite ou l'exfiltration non autorisée de données.
Infostealer	Code malveillant collectant des informations, notamment des authentifiants, souvent à l'origine d'une fuite de données.
CTI	Renseignement sur la menace cyber, permettant une veille en anticipation des fuites de données.

Auto-test

1. Quel principe du RGPD impose d'intégrer la protection des données à chaque étape de conception ?
2. Quels sont les trois types de minimisation des accès cités ?
3. Que permet de faire un logiciel DLP ?
4. Quel outil peut être utilisé pour la réaction face à une fuite ?
5. Pourquoi est-il indispensable de comprendre la source d'une fuite avérée ?

Réponses : **1.** La protection des données dès la conception et par défaut. · **2.** Par rôle, par zone et par créneaux horaires. · **3.** Détecter et prévenir la fuite ou l'exfiltration non autorisée de données. · **4.** haveibeenpwned.com. · **5.** Pour éviter qu'une nouvelle compromission n'exploite le même vecteur.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.